AI-SOC: Hibrit İki Kademeli Siber Savunma Sistemi

Deneysel Ölçüm, Adversarial Dayanıklılık ve Model Güvenliği Değerlendirme Raporu
Dürüst Mühendislik Değerlendirmesi • Tüm Metrikler data/*.json Dosyalarından Dinamik Çekilmiştir

Rapor Tarihi: 24.10.2026 00:40	Veri Seti: Sentetik (CIC-IDS2017 Benzeri, scripts/make_dataset.py)
Tier 1 ML Filtresi: Online SGDClassifier + Multi-Pass Normalizer	Tier 2 Analiz: Deterministic Rule Engine (Ollama Unreachable/Offline)
Test Seti Boyutu: 256 Akış + 47 Adversarial	Geri Bildirim Modu: Batch Boyutu 3 + Holdout Rollback

1. Mimari Tasarım ve İki Aşamalı İşlem Ayrımı

Bu çalışma, siber güvenlik operasyon merkezlerinde (SOC) akan yüksek hacimli ham log trafiğini doğrudan büyük dil modellerine (LLM) göndermenin getirdiği yüksek maliyet, donanım darboğazı ve gecikme sorunlarını çözmek üzere tasarlanmış iki kademeli (Two-Stage Event-Driven) bir mimaridir.
• Tier 1 (CPU ML + Regex Katmanı): Gelen her logu ve akış özelliklerini CPU üzerinde mikrosaniye mertebesinde (Ortalama: 0.182 ms, P95: 0.386 ms) değerlendirir. Şüpheli bulunmayan normal loglar elenir.
• Tier 2 (Derin LLM Analisti): Yalnızca Tier 1 tarafından şüpheli olarak işaretlenen loglar için tetiklenir; semantik doğrulama, MITRE ATT&CK; eşleştirmesi ve koda dayalı güvenli savunma kuralı sentezler.

2. Tier 1 Akış Modeli Performansı ve Karşılaştırma

Veri kaynağı olarak Sentetik (CIC-IDS2017 Benzeri, scripts/make_dataset.py) kullanılmıştır. Model seçimini doğrulamak adına aynı veri kümesinde 5-katlı çapraz doğrulama (5-Fold Cross Validation) ile 4 farklı mimari karşılaştırılmıştır:

Model / Öznitelik Seti	F1-Skoru	Doğruluk (Acc)	Hassasiyet (Prec)	Duyarlılık (Rec)	Gerekçe / Rol
Baseline Sgd Raw Features	0.5709	0.7344	0.8855	0.4896	Eski ham port (skaler) modeli
New Sgd Log1P Port Flags	0.9419	0.9570	0.9604	0.9271	Seçilen Online Model (partial_fit)
Decision Tree Depth 4	0.9855	0.9891	0.9839	0.9875	Kural derinlik 4 referansı
Random Forest 100	1.0000	1.0000	1.0000	1.0000	Topluluk (Ensemble) tavan referansı

Ayrık Test Seti Sonuçları (Eşik = 0.65): Doğruluk: %97.27 | F1-Skor: 0.9622 | Hassasiyet: %100.00 | Duyarlılık: %92.71 | Yanlış Alarm Oranı (FPR): %0.00
Karmaşıklık Matrisi: TN = 160, FP = 0 (Yanlış Alarm), FN = 7 (Kaçırılan), TP = 89 (Doğru Tespit).

3. Adversarial Dayanıklılık ve Kaçırılan Örnekler

Sistem, data/payloads_test.json test setinde yer alan toplam 47 farklı gizleme (obfuscation) varyantı ve 108 masum log ile test edilmiştir. Testlerde ML katmanına yapay avantaj sağlamamak için nötr (masum) akış özellikleri verilmiş ve regex, ML ve birleşik sonuçlar dürüstçe ayrıştırılmıştır:

Saldırı Ailesi	Test Sayısı	Regex Tespit	ML Tespit	Birleşik Tespit	Tespit Oranı
SQLi	22	21	0	21	**%95.5**
XSS	15	15	0	15	**%100.0**
SSH	10	2	10	10	**%100.0**
GENEL TOPLAM	**47**	**38**	**10**	**46**	**%97.9**

□□ Dürüstlük İlkesi Gereği Açıklanan Kaçırılan Örnekler (1 Adet):
• [SQLi] CHAR Function Obfuscation: GET /auth?user=' OR user=CHAR(97,100,109,105,110) HTTP/1.1 200 (Skor: 0.0081)
Analiz: CHAR() fonksiyonunun çoklu argüman içeren varyantı çıplak regex'ten kaçmıştır. Bu durum sistemin kör noktası olarak raporlanmış olup dev/test ayrımı kuralı gereğince test setinde gizlenmemiştir.

4. Tier 2 Tehdit İstihbaratı ve Komut Güvenliği

Tier 2 değerlendirmesinde 47 test saldırısı analiz edilmiştir. İnceleme motoru: Deterministic Rule Engine (Ollama Unreachable/Offline) (Fallback Modu Aktif).
• Saldırı Tipi Eşleşme Doğruluğu: %70.2
• MITRE ATT&CK; Tekniği Eşleşmesi: %70.2
• Komut Güvenliği ve IP Uyumluluğu: %100.0 (İç IP / Chaining Engelleme Hatası: 0)
• Ortalama Analiz Süresi: 248.54 ms (P95: 286.33 ms)

5. Sürekli Öğrenme ve Geri Bildirim Zehirlenme Dayanıklılığı

Operatör geri bildirimleriyle sürekli öğrenme (Continual Learning) iki kritik teste tabi tutulmuştur:
• Test 1 (Sağlamlık - 10 Doğru Geri Bildirim): Başlangıç Holdout F1: 0.6825 -> Geri Bildirim Sonrası: 0.8199 (□ Başarılı - Bozulma Yok).
• Test 2 (Anti-Poisoning - 5 Kasıtlı Zehirleme Saldırısı): Saldırgan DDoS akışlarına 'normal', masum loglara 'saldırı' diyerek modeli zehirlemeye çalışmıştır. Holdout F1 düşüşü izlenmiş ve 5 adet otomatik geri alma (Rollback) tetiklenerek katastrofik sürüklenme engellenmiştir. Sonuç: 0.8199 F1 (□ Başarılı - Zehirlenme Engellendi).

6. Sistemin Sınırlamaları ve Gelecek Çalışma

Bu proje akademik dürüstlük ve tekrarlanabilirlik ilkeleri doğrultusunda geliştirilmiş olup aşağıdaki bilinen kısıtlara sahiptir:
• 1. Yavaş ve Dağıtık SSH Brute-Force: Brute-force tespiti IP başına 60 saniyelik kayan pencerede en az 5 başarısız denemeye bakar. Bir botnet farklı IP'lerden veya 120 saniye aralıklarla parola denerse bu pencereyi aşabilir. Gelecek çalışmada kümeleme (clustering) ve alt ağ bazlı sayıcılar gereklidir.
• 2. Web Saldırılarının Akış Düzeyinde Masum Trafikle Örtüşmesi: SQLi ve XSS gibi uygulama katmanı saldırıları akış özellikleri (paket boyutu, süre, bayt hızı) bakımından masum GET/POST istekleriyle neredeyse birebir örtüşür. Bu nedenle akış modeli tek başına web saldırılarını ayıramaz; metin normalizasyonu ve regex/LLM katmanı zorunlu bir tamamlayıcıdır.
• 3. Sentetik Veri Kullanımı ve Kavram Kayması (Concept Drift): Kullanılan veri sentetiktir (scripts/make_dataset.py). Gerçek üretim ortamlarındaki CDN trafiği, asenkron WebSocket akışları ve kullanıcı davranışları sentetik modelde dağılım kaymasına (distribution shift) yol açabilir.
• 4. İki Kademeli Savunmanın Kör Noktaları: gzip sıkıştırmalı HTTP gövdeleri, UTF-16/EBCDIC kodlamaları veya chunked transfer encoding ile parçalanmış payload'lar soket seviyesinde yeniden birleştirilmediği (reassembly) sürece metin ön filtresini atlatabilir.